Definitions - A

PURPOSE: This document provides a list of words and definitions to clarify Information Specific (IT) terminology contained within the State of Wyoming Policies and Standards.

I. APPLICABILITY

This policy applies to all Executive Branch agencies, boards, and commissions staff (collectively referred to as "agencies"). This policy is also applicable to consultants, affiliates, and temporary employees.

II. DEFINITIONS

- Acceptance: The point at which the end-users of a system declare, formally, that the system meets their needs and has performed satisfactorily during the test procedures. Unless a system has been acquired, installed, or amended, purely for the IT department it is not sufficient for technical staff to declare it acceptable; the end users must be involved.

- Access (Logical): The process of being able to enter, modify, delete, or inspect records and data held on a computer system by means of providing an ID and password (if required). The view that restricting physical access relieves the need for logical access restrictions is misleading. Any Agency with communications links to the outside world has a security risk of logical access. (SOURCE: The Information Security Glossary)

- Access: Ability to make use of any information system (IS) resource. (SOURCE: NIST SP 800-32) Ability and means to communicate with or otherwise interact with a system, to use system resources to handle information, to gain knowledge of the information the system contains, or to control system components and functions. (SOURCE: CNSSI-4009)

- Access Control: The process of granting or denying specific requests to: 1. obtain and use information and related information processing services; and 2. enter specific physical facilities (e.g., federal buildings, military establishments, and border crossing entrances). (SOURCE: FIPS 201; CNSSI-4009)

- Access Control List (ACL): 1. A list of permissions associated with an object. The list specifies who or what is allowed to access the object and what operations are allowed to be performed on the object. 2. A mechanism that implements access control for a system resource by enumerating the system affiliates that are permitted to access the resource and stating, either implicitly or explicitly, the access modes granted to each affiliate. (SOURCE: CNSSI-4009)

- Access Control Mechanism: Security safeguards (i.e., hardware and software features, physical controls, operating procedures, management procedures, and various combinations of these) are designed to detect and deny unauthorized access and permit authorized access to an information system. (SOURCE: CNSSI-4009)

- Access Level: A category within a given security classification limiting entry or system connectivity to only authorized persons. (SOURCE: CNSSI-4009)

- Access List: Roster of individuals authorized admittance to a controlled area. (SOURCE: CNSSI-4009)

- Access Management: A discipline that focuses on ensuring that only approved roles are able to create, read, update, or delete data – and only using appropriate and controlled methods. Data Governance programs often focus on supporting Access Management by aligning the requirements and constraints posed by Governance, Risk Management, Compliance, Security, and Privacy efforts. (SOURCE: Data Governance Institute)

- Access Point: A device that logically connects wireless client devices operating in infrastructure to one another and provides access to a distribution system, if connected, which is typically an organization's enterprise network. (SOURCE: NIST SP 800-48; NIST SP 800-121)

- Access Profile: Association of a user with a list of protected objects the user may access. (SOURCE: CNSSI-4009)

- Account Management, User: Involves: 1. the process of requesting, establishing, issuing, and closing user accounts; 2. tracking users and their respective access authorizations; and 3. managing these functions.
- (SOURCE: NIST SP 800-12)

- Accountability: The security goal that generates the requirement for the actions of an affiliate to be traced uniquely to that affiliate. This supports non- repudiation, deterrence, fault isolation, intrusion detection and prevention, and after-action recovery and legal action. (SOURCE: NIST SP 800-27) Principle that an individual is entrusted to safeguard and control equipment, keying material, and information and is answerable to proper authority for the loss or misuse of that equipment or information. (SOURCE: CNSSI-4009)

- Activation Data: Private data, other than keys, that are required to access cryptographic modules. (SOURCE: NIST SP 800-32)

- Active Attack: An attack that alters a system or data. (SOURCE: CNSSI-4009)

- Active Security Testing: Security testing that involves direct interaction with a target, such as sending a packet to a target. (SOURCE: NIST SP 800-115)

- Ad Hoc Network: A wireless network that dynamically connects wireless client devices to each other without the use of an infrastructure device, such as an access point or a base station. (SOURCE: NIST SP 800-121)

- Add-on Security: Incorporation of new hardware, software, or firmware safeguards in an operational information system. (SOURCE: CNSSI-4009)

- Adequate Security: Security commensurate with the risk and the magnitude of harm resulting from the loss, misuse, or unauthorized access to or modification of information. (SOURCE: NIST SP 800-53; FIPS 200; OMB Circular A-130, App. III) Security commensurate with the risk and magnitude of harm resulting from the loss, misuse, or unauthorized access to or modification of information.

  Note: This includes assuring that information systems operate effectively and provide appropriate confidentiality, integrity, and availability, through the use of cost-effective management, personnel, operational, and technical

controls. (SOURCE: CNSSI-4009; NIST SP 800-37)

- Administrative Account: A user account with full privileges on a computer. (SOURCE: NIST SP 800-69)

- Administrative Safeguards: Administrative actions, policies, and procedures to manage the selection, development, implementation, and maintenance of security measures to protect electronic health information and to manage the conduct of the covered affiliate's workforce in relation to protecting that information. (SOURCE: NIST SP 800-66)

- Advanced Persistent Threats (APT): An adversary that possesses sophisticated levels of expertise and significant resources that allow it to create opportunities to achieve its objectives by using multiple attack vectors (e.g., cyber, physical, and deception). These objectives typically include establishing and extending footholds within the information technology infrastructure of the targeted organizations for purposes of exfiltrating information, undermining or impeding critical aspects of a mission, program, or organization, or positioning itself to carry out these objectives in the future. The advanced persistent threat: 1. pursues its objectives repeatedly over an extended period of time 2. adapts to defenders' efforts to resist it; and 3. is determined to maintain the level of interaction needed to execute its objectives. (SOURCE: NIST SP 800-39)

- Adversary: Individual, group, organization, or government that conducts or has the intent to conduct detrimental activities. (SOURCE: NIST SP 800-30)

- Advisory: Notification of significant new trends or developments regarding the threat to the information systems of an organization. This notification may include analytical insights into trends, intentions, technologies, or tactics of an adversary targeting information systems. (SOURCE: CNSSI-4009)

- Affiliates: Individuals or entities that are closely associated with or connected to the State of Wyoming, typically in a business or contractual context. Affiliates may include consultants, contractors, subsidiaries, or third parties who have a working relationship or association with the State for collaborative or operational purposes; shall not include the Wyoming Judiciary and Legislative Branches, University of Wyoming, and Wyoming community colleges.

- Affordable Care Act: U.S. federal statute signed into law on March 23, 2010,

with the goal of expanding public and private insurance coverage and reducing the cost of healthcare for individuals and the government. (SOURCE: IRS PUB 1075)

- Agency: The term “agency” is used to refer to any Department, Agency, Commission, Board, Body, or other instrumentality of the Executive Branch.

- Agent: A program acting on behalf of a person or organization. (SOURCE: NIST SP 800-95)

- Alert: Notification that a specific attack has been directed at an organization’s information systems. (SOURCE: CNSSI-4009)

- Algorithm: A computerized procedure consisting of a set of steps used to accomplish a determined task.

- Alternate Processing Site: Locations and infrastructures from which emergency or backup processes are executed when the main premises are unavailable or destroyed. (SOURCE: ISACA)

- Analysis: The examination of acquired data for its significance and probative value to the case. (SOURCE: NIST SP 800-72)

- Anomaly-Based Detection: The process of comparing definitions of what activity is considered normal against observed events to identify significant deviations. (SOURCE: NIST SP 800-94)

- Anti-spoof: Countermeasures taken to prevent the unauthorized use of legitimate Identification & Authentication (I&A) data, however it was obtained, to mimic a subject different from the attacker. (SOURCE: CNSSI-4009)

- Anti-Virus Software: A program that monitors a computer or network to identify all major types of malware and prevent or contain malware incidents. (SOURCE: NIST SP 800-83)

- Anti-spyware Software: A program that specializes in detecting both malware and non-malware forms of spyware. (SOURCE: NIST SP 800-69)

- Application: A software program hosted by an information system. (SOURCE: NIST SP 800-37)

- Application Program Interface (API): An API specifies how some software

components should interact with each other. In addition to accessing databases or computer hardware, such as hard disk drives or video cards, an API can be used to ease the work of programming graphical user interface components. In practice, many times an API comes in the form of a library that includes specifications for routines, data structures, object classes, and variables. In some other cases, notably for SOAP and REST services, an API comes as just a specification of remote calls exposed to the API consumers. (SOURCE: WIKIPEDIA)

- Application Service Providers (ASPs): Companies that offer individuals or enterprises access over the Internet to applications and related services that would otherwise have to be located in their own personal or enterprise computers. Sometimes referred to as "apps-on-tap," ASP services are expected to become an important alternative, not only for smaller companies with low budgets for information technology but also for larger companies as a form of outsourcing and for many services for individuals as well. Most corporations are essentially providing their own ASP service in-house, moving applications off personal computers and putting them on a special kind of application server that is designed to handle the stripped-down kind of thin-client workstation. This allows an enterprise to reassert the central control over application cost and usage that corporations formerly had prior to the advent of the PC. (SOURCE: TechTarget)

- Approved Security Function: A security function (e.g., cryptographic algorithm, cryptographic key management technique, or authentication technique) that is either: 1. specified in an Approved Standard 2. adopted in an Approved Standard, and specified either in an appendix of the Approved Standard or in a document referenced by the Approved Standard; or 3. specified in the list of Approved security functions. (SOURCE: FIPS 140-2)

- Artificial Intelligence System: Systems capable of perceiving an environment through data acquisition and then processing and interpreting the derived information to take an action or actions or to imitate intelligent behavior given a specific goal. An artificial intelligence system can also learn and adapt its behavior by analyzing how the environment is affected by prior actions.

- Assessment: See Security Control Assessment.

- Assessment Findings: Assessment results produced by the application of an assessment procedure to a security control or control enhancement to achieve an assessment objective; the execution of a determination

statement within an assessment procedure by an assessor that results in either a satisfied or other than satisfied condition. (SOURCE: NIST SP 800-53A)

- Assessment Method: One of three types of actions (i.e., examine, interview, test) taken by assessors in obtaining evidence during an assessment. (SOURCE: NIST SP 800-53A)

- Assessment Object: The item (i.e., specifications, mechanisms, activities, individuals) upon which an assessment method is applied during an assessment. (SOURCE: NIST SP 800-53A)

- Assessment Procedure: A set of assessment objectives and an associated set of assessment methods and assessment objects. (SOURCE: NIST SP 800-53A)

- Asset Owner: A person or organizational unit (internal or external to the organization) with primary responsibility for the viability, productivity, security, and resilience of an organizational asset. (SOURCE: CERT RMM)

- Assurance: Grounds for confidence that the other four security goals (integrity, availability, confidentiality, and accountability) have been adequately met by a specific implementation. “Adequately met” includes: 1. functionality that performs correctly, 2. sufficient protection against unintentional errors (by users or software), and 3. sufficient resistance to intentional penetration or bypass. (SOURCE: NIST SP 800-27)

  The grounds for confidence that the set of intended security controls in an information system are effective in their application. (SOURCE: NIST SP 800-37; NIST SP 800-53A)

  Measure of confidence that the security features, practices, procedures, and architecture of an information system accurately mediate and enforce the security policy. (SOURCE: CNSSI-4009; NIST SP 800-39)

  In the context of OMB M-04-04 and this document, assurance is defined as: 1. the degree of confidence in the vetting process used to establish the identity of an individual to whom the credential was issued, and 2. the degree of confidence that the individual who uses the credential is the individual to whom the credential was issued. (SOURCE: NIST SP 800-63)

- Assured Information Sharing: The ability to confidently share information with those who need it, when and where they need it, as determined by

operational need and an acceptable level of security risk. (SOURCE: CNSSI-4009)

- Assured Software: Computer application that has been designed, developed, analyzed, and tested using processes, tools, and techniques that establish a level of confidence in it. (SOURCE: CNSSI-4009)

- Attack: An attempt to gain unauthorized access to system services, resources, or information or an attempt to compromise system integrity. (SOURCE: NIST SP 800-32)

- Attack Sensing and Warning (AS&W): Detection, correlation, identification, and characterization of intentional unauthorized activity with notification to decision-makers so that an appropriate response can be developed. (SOURCE: CNSSI-4009)

- Attack Signature: A specific sequence of events indicative of an unauthorized access attempt. (SOURCE: NIST SP 800-12)

- Attack Surface: The set of points on the boundary of a system, a system component, or an environment where an attacker can try to enter, cause an effect on, or extract data from that system, component, or environment.

- Audit: Independent review and examination of records and activities to assess the adequacy of system controls, to ensure compliance with established policies and operational procedures, and to recommend necessary changes in controls, policies, or procedures. (SOURCE: NIST SP 800-32) Independent review and examination of records and activities to assess the adequacy of system controls to ensure compliance with established policies and operational procedures. (SOURCE: CNSSI-4009)

- Audit Data: Chronological record of system activities to enable the reconstruction and examination of the sequence of events and changes in an event. (SOURCE: NIST SP 800-32)

- Audit Log: A chronological record of system activities. Includes records of system accesses and operations performed in a given period. (SOURCE: CNSSI-4009)

- Audit Review: The assessment of an information system to evaluate the adequacy of implemented security controls, assure that they are functioning properly, identify vulnerabilities, and assist in the implementation of new security controls where required. This assessment is conducted annually or

whenever a significant change has occurred and may lead to recertification of the information system. (SOURCE: CNSSI-4009)

- Audit Trail: A record showing who has accessed an Information Technology (IT) system and what operations the user has performed during a given period. (SOURCE: NIST SP 800-47) A chronological record that reconstructs and examines the sequence of activities surrounding or leading to a specific operation, procedure, or event in a security-relevant transaction from inception to final result. (SOURCE: CNSSI-4009)

- Authenticate: To confirm the identity of an affiliate when that identity is presented. (SOURCE: NIST SP 800-32)

- Authentication: Verifying the identity of a user, process, or device, often as a prerequisite to allowing access to resources in an information system. (SOURCE: NIST SP 800-53; NIST SP 800-53A; NIST SP 800-27; FIPS 200; NIST SP 800-30)

- Authentication Mechanism: Hardware-or software-based mechanisms that force users to prove their identity before accessing data on a device. (SOURCE: NIST SP 800-72; NIST SP 800-124)

- Authentication Period: The maximum acceptable period between any initial authentication process and subsequent re-authentication processes during a single terminal session or during the period data is being accessed. (SOURCE: CNSSI-4009)

- Authentication Protocol: A defined sequence of messages between a Claimant and a Verifier that demonstrates that the Claimant has possession and control of a valid token to establish their identity and, optionally, demonstrates to the Claimant that he or she is communicating with the intended Verifier. (SOURCE: NIST SP 800-63); A well-specified message exchange process between a claimant and a verifier that enables the Verifier to confirm the Claimant's identity. (SOURCE: CNSSI-4009)

- Authenticator: The means used to confirm the identity of a user, process, or device (e.g., user password or token). (SOURCE: NIST SP 800-53; CNSSI-4009)

- Authenticity: The property of being genuine and being able to be verified and trusted; confidence in the validity of a transmission, a message, or message originator. See authentication. (SOURCE: NIST SP 800-53; NIST SP 800-53A; CNSSI-4009; NIST SP 800-39)

- Authority: Person(s) or established bodies with rights and responsibilities to exert control in an administrative sphere. (SOURCE: CNSSI-4009.
- Authorization: Access privileges granted to a user, program, or process or the act of granting those privileges. (SOURCE: CNSSI-4009)

- Automated Decision System: Any algorithm, including one incorporating machine learning or other artificial intelligence techniques, that uses data-based analytics to make or support government decisions, judgments, or conclusions.

- Automated Final Decision System: An automated decision system that makes final decisions, judgments, or conclusions without human intervention.

- Automated Security Monitoring: Use of automated procedures to ensure security controls are not circumvented or the use of these tools to track actions taken by subjects suspected of misusing the information system. (SOURCE: CNSSI-4009)

- Automated Support Decision System: An automated decision system that provides information to inform the final decision, judgment, or conclusion of a human decision-maker.

- Availability: In the context of information security, refers to ensuring timely and reliable access to and use of information. The loss of availability is the disruption of access to or use of information or an information system. [44 U.S.C., Sec. 3542]

- Awareness (Information Security): Activities that seek to focus an individual's attention on an (information security) issue or set of issues. (SOURCE: NIST SP 800-50)

DOCUMENT HISTORY

ORIGINAL SUBMISSION				
SUBMITTED ON	SUBMITTED BY	APPROVED BY	ISSUED DATE	EFFECTIVE DATE

REVISIONS		
LAST REVISION DATE	LAST REVISED BY	LAST APPROVED BY

REVIEWS		
LAST REVIEW DATE	LAST REVIEWED BY	NEXT REVIEW DATE